ANTECH SOLUTIONS

Task Tracker

Security Report · version 1.0.0

Version	**1.0.0**
Date	**2026-10-30**
Prepared by	**Scribe, Antech /ship engineering team**
Prepared for	**CEO Nageshwar**
Contents	**Security Report, Security Audit Checklist**

Contents

1. Security Report
    1. Executive summary
    2. Scope
    3. Method
    4. Findings
    5. Controls confirmed
    6. Recommendations
    7. Sign-off
2. Security Audit Checklist
    Findings
    Checklist

SECURITY REPORT

Security Report - Task Tracker v1.0.0

Product	Task Tracker v1.0.0 (REST API, web app, Android app)
Assessment	Static code review, configuration review, automated security regression tests
Assessor	Armor (security agent), report compiled by Scribe
Date	2026-10-30
Commit assessed	`feat/task-tracker`, release tag `task-tracker-v1.0.0`
Verdict	**Approved for release.** 0 Critical, 0 High open. 4 findings fixed, 2 Low risks accepted for v1

1. Executive summary

Task Tracker was reviewed against the OWASP Top 10 (2021) for the API and web app and the OWASP Mobile Top 10 for the Android app. Armor found **four issues during development, all fixed before release**: three caused server errors (HTTP 500) on bad input or exposed a generated password in the startup log, and one removed an unneeded database console component. Each fix has an automated regression test that runs on every build.

Two **low risks are accepted** for v1.0.0 by product scope: the API has **no user login** (single-team use, no personal data), and the **debug Android build** may talk to a local test server over plain HTTP. Adding authentication is the main recommendation for v1.1.

Severity	Found	Fixed	Accepted	Open
Critical	0	0	0	0
High	0	0	0	0
Medium	3	3	0	0
Low	3	1	2	0

2. Scope

Component	In scope
Spring Boot REST API (`backend/src/main/java`)	Controllers, services, repository, validation, error handling, security configuration
Configuration (`application.yml`, `pom.xml`)	Profiles, secrets handling, actuator, CORS, dependencies
Web app (`static/index.html`, `app.js`, `styles.css`)	XSS, script sources, data handling
Android app (`android/app`)	Data storage, permissions, network security, backups, exported components, SQL
Build and CI (`.github/workflows/task-tracker-ci.yml`)	Secrets handling, signing, supply chain

Out of scope: infrastructure hosting, penetration testing of a deployed instance, and the Android UI on physical devices.

3. Method

1. Contract review in the architecture phase (data model, endpoints, sync design).
2. Line-by-line review of all changed files against the checklist in the Security Audit Checklist section.
3. Automated scans: secret patterns (`password=`, `secret`, `api_key`, private keys) across Java, YAML, JS, XML and Gradle files, and a search for unsafe DOM APIs (`innerHTML`, `eval`, `document.write`).
4. Security regression tests in `TaskApiIntegrationTest`: `badInputNeverReturns500`, `errorsDoNotLeakInternals`, `securityHeadersAndCors`, run on every CI build.
5. Startup log inspection for credentials.

4. Findings

SEC-1 - Unknown sort field caused a server error (Medium, fixed)

- **Where:** `GET /api/v1/tasks?sort=<field>`
- **Issue:** an unknown field name (for example `sort=bogus,asc`) reached the catch-all error handler and returned HTTP 500. Repeated 500s hide real faults, add noise to monitoring and reveal that input reaches the data layer unchecked.
- **Fix:** `GlobalExceptionHandler` maps `PropertyReferenceException` to `400 malformed-request`.
- **Verification:** `badInputNeverReturns500` asserts 400; smoke test on the shipped JAR returned 400.

SEC-2 - Missing or invalid parameters caused server errors (Medium, fixed)

- **Where:** `GET /api/v1/tasks/changes` without `since`, unsupported content types and other framework errors.
- **Issue:** these fell through to the catch-all handler and returned 500 instead of a 4xx status.
- **Fix:** `MissingServletRequestParameterException` returns 400, and every Spring MVC error with a 4xx status (415, 405, 406...) keeps that status with a generic message.
- **Verification:** `badInputNeverReturns500` covers missing `since`, invalid `since`, non-UUID id, malformed JSON, unknown enum value and `text/plain` (415).

SEC-6 - Generated password written to the startup log (Medium, fixed)

- **Where:** application startup.
- **Issue:** Spring Boot created a default in-memory user and printed `Using generated security password: ...` to the log. Credentials in logs can leak through log shipping and support tickets.
- **Fix:** `SecurityConfig` declares an empty `InMemoryUserDetailsManager`, so no default user or password exists.
- **Verification:** test logs searched after the fix: no generated password present.

SEC-3 - Unused database console dependency (Low, fixed)

- **Where:** `pom.xml` (`spring-boot-h2console`, added by the project generator).
- **Issue:** a web database console is a common attack target if accidentally enabled.
- **Fix:** dependency removed; `spring.h2.console.enabled: false`.

SEC-4 - No authentication in v1.0.0 (Low, accepted)

- **Where:** all `/api/v1/**` endpoints.
- **Issue:** anyone who can reach the server can read and change tasks.
- **Why accepted:** single-team scope agreed in the specification; tasks contain no personal or financial data.
- **Mitigation now:** run on a trusted network or behind a reverse proxy that requires sign-in (Quick Start, Step 8).
- **Planned:** login and per-user ownership checks in v1.1.

SEC-5 - Debug Android build allows HTTP to local test hosts (Low, accepted)

- **Where:** `android/app/src/debug/res/xml/network_security_config.xml`.
- **Issue:** the debug build may send traffic unencrypted to `10.0.2.2` (emulator host) and `localhost`.
- **Why accepted:** debug-only and limited to the two loopback test hosts; release builds allow HTTPS only, and the in-app Server URL setting rejects `http://` in release builds.

5. Controls confirmed

Area	Control
Input validation	Bean Validation on every request body (`@NotBlank`, `@Size`), typed UUID, date, instant and enum binding
Injection	Spring Data derived queries only; Android SQL uses `ContentValues` and `?` arguments
Error handling	RFC 7807 responses without stack traces, exception names or framework messages; 500s get a correlation id in the server log
Transport and headers	CSP `default-src 'self'`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer`
CORS	Explicit allow-list from `APP_CORS_ALLOWED_ORIGINS`; other origins get 403 (tested)
Secrets	None in the repository; production database and APK signing keys come from environment variables and GitHub secrets
Exposure	Only static files, API docs, `/actuator/health` and `/actuator/info`, and `/api/v1/**`; everything else denied
Abuse limits	Page size capped at 100, sync feed capped at 500 rows, field length limits
Web XSS	All data rendered with `textContent`; no inline scripts or event handlers; no third-party scripts
Mobile storage	SQLite and settings in app-private internal storage; no storage permissions; backups and device transfer excluded
Mobile components	Only the launcher activity is exported; release builds minified with debug logs stripped

6. Recommendations

Priority	Recommendation	Target
High	Add authentication (for example OAuth2/OIDC or session login) and per-user task ownership	v1.1
Medium	Add rate limiting at the reverse proxy for `/api/v1/**`	Deployment
Medium	Configure APK release signing (`ANTECH_KEYSTORE_*` secrets) before wider distribution	Next release
Low	Add dependency vulnerability scanning (for example OWASP Dependency-Check or GitHub Dependabot) to CI	Next sprint

Priority	Recommendation	Target
Low	Add Flyway migrations and run production with `JPA_DDL_AUTO=validate`	v1.1

7. Sign-off

Armor approves Task Tracker v1.0.0 for release: no Critical or High findings are open, all Medium findings are fixed and covered by automated tests, and the remaining Low risks are documented and accepted within the agreed scope. The detailed per-control checklist follows in the Security Audit Checklist section.

SECURITY AUDIT CHECKLIST

Security audit - Task Tracker v1.0.0 (Armor)

Result: SIGNED OFF - 0 Critical, 0 High open. 4 findings fixed, 2 Low accepted.

Findings

ID	Severity	Location	Issue	Status
SEC-1	Medium	`GET /api/v1/tasks?sort=<unknown>`	Unknown sort property hit the catch-all handler and returned 500	Fixed - `PropertyReferenceException` -> 400; regression test `badInputNeverReturns500`
SEC-2	Medium	`GET /api/v1/tasks/changes` without `since`; other Spring MVC errors	Returned 500 instead of 4xx	Fixed - `MissingServletRequestParameterExcepti` -> 400, any `ErrorResponse` 4xx keeps its status (415, 405, 406...)
SEC-3	Low	`pom.xml`	Initializr added `spring-boot-h2console`	Fixed - dependency removed, console disabled
SEC-6	Medium	Startup log	Spring Boot's generated default user printed `Using generated security password` to the log	Fixed - empty `InMemoryUserDetailsManager` bean; verif no password in test logs
SEC-4	Low	API	No authentication in v1 (single tenant, no personal data)	Accepted by Spec/CEO scope - planned f v1.1
SEC-5	Low	Android	Debug build allows cleartext to `10.0.2.2` / `localhost`	Accepted - debug-only `src/debug` netw config; release is HTTPS-only

Checklist

Check	Result	Evidence
A01 Access control	N/A v1 (SEC-4)	`SecurityConfig`: only static files, docs, health and `/api/v1/**` exposed; everything else `denyAll`
A02 Crypto	PASS	No credentials stored; HTTPS required for Android release
A03 Injection	PASS	Spring Data derived queries only; `@Valid` on every body; UUID/`Instant`/enum binding rejects bad input with 400
A04 Insecure design	PASS	`@Size` limits, page size capped at 100, `/changes` capped at 500 rows
A05 Misconfiguration	PASS	No stack traces/messages in errors (`errorsDoNotLeakInternals`), actuator only `health,info`, CORS allow-list (`securityHeadersAndCors`)
A06 Components	PASS	Spring Boot 4.1.2, springdoc 3.2.0, no unused dependencies
A08 Integrity	PASS	CI uses pinned action major versions, no `curl | sh`
A09 Logging	PASS	500s logged server-side with correlation id; client gets generic detail
S1 Secrets	PASS	Secret scan of `*.java, *.yml, *.js, *.xml, *.gradle`: none. Prod DB and keystore come from env vars
S2 Headers	PASS	CSP `default-src 'self'`, `nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer`
S3 CSRF	PASS	Stateless JSON API without cookies; CSRF disabled by design
Web XSS	PASS	No `innerHTML`/`eval`/`document.write`; all data rendered via `textContent`
Mobile storage	PASS	SQLite + SharedPreferences in app-private internal storage only; no storage permissions; `allowBackup=false`; backup/extraction rules exclude all data
Mobile network	PASS	Release `cleartextTrafficPermitted=false`; base URL setter rejects non-HTTPS in release
Mobile SQL	PASS	`ContentValues` and `?` args only
Exported components	PASS	Only the launcher activity is exported